

Vulnerability assessment report

E-commerce database server. 1st January 20XX.

System description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs the latest version of the Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment covers a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 guides the risk analysis of the information system.

Purpose

The database server is central to business operations. It stores the customer and product information that a globally distributed, remote workforce queries every day to find and serve customers, which ties it directly to revenue. Securing the data protects customer privacy and the confidentiality and integrity of information the business depends on, and it limits regulatory and reputational exposure. If the server were disabled, employees worldwide would lose access to the data they need, halting core operations and interrupting sales. This assessment communicates those risks to decision makers and outlines how the currently public-facing server can be secured.

Risk assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker (outsider)	Obtain sensitive information via exfiltration	3	3	9
Hacktivist (outsider)	Conduct Denial of Service (DoS) attacks	2	3	6
Competitor (group)	Perform reconnaissance and surveillance of organization	3	1	3

Scoring per NIST SP 800-30 Rev. 1: likelihood (1 low, 2 moderate, 3 high) x severity (1 low, 2 moderate, 3 high) = risk (1 to 9).

Approach

This is a qualitative assessment, so likelihood and severity were scored using security knowledge and judgment rather than statistical data. The three threats were selected because each follows directly from the central finding that the database has been publicly accessible for three years. Public exposure makes exfiltration almost certain and catastrophic given the customer data at stake, which is why it scores highest. A denial-of-service attack is somewhat less likely but would be severe, since disabling the server stops a remote workforce from operating. Reconnaissance is near certain against an open server but low in direct impact, acting mainly as a precursor to the other two events.

Remediation strategy

The root cause is unrestricted public access, so the priority control is IP allow-listing that limits connections to corporate networks and known office ranges, closing the exposure that drives all three risks. Authentication, authorization, and auditing should be enforced through role-based access control, a strong password policy, and

multi-factor authentication, applying least privilege so accounts hold only the access their role requires. Data in motion should use current TLS rather than legacy SSL to defend against interception and man-in-the-middle attempts. Rate limiting and DDoS protection at the network edge reduce the severity of denial-of-service attempts. Together these controls apply defense in depth across the identified risks.